

TAREA NDC03

**Legislación para el cumplimiento de la
responsabilidad penal.**

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Catálogo de Ciber-Riesgos Penales.....	3
Respuestas 1	3
Apartado 2: Matriz de Riesgo y Controles Mitigantes	4
Respuestas 2	5
Apartado 3: Adecuación a la Ley 2/2023 y NIS2.....	6
Respuestas 3	7

Detalles de la tarea de esta unidad

Caso práctico

ACME S.A. sigue siendo una "Telco" líder con 300.000 clientes, presencia internacional y contratos con embajadas y banca. Su infraestructura física es moderna y sostenible.

Estamos en el año en curso. La entrada en vigor de la Ley 2/2023 (Protección del Denunciante) y la transposición de la Directiva NIS2 han cambiado las reglas del juego.

El Consejo de Administración de ACME está muy nervioso. Han recibido una notificación legal advirtiéndoles que, al ser una empresa de telecomunicaciones, ahora son considerados "Entidad Esencial". Además, el Director General ha leído que, bajo la nueva normativa, él podría responder con su patrimonio personal o ser inhabilitado si ocurre un ciberataque grave por falta de diligencia.

Como responsable de Seguridad y Cumplimiento (CISO/Compliance Officer), se te ha encargado actualizar el "Mapa de Riesgos Penales" y definir los requisitos para las nuevas obligaciones legales

Debes elaborar un informe técnico para la Dirección dando respuesta a los siguientes tres apartados

Apartado 1: Catálogo de Ciber-Riesgos Penales

En lugar de listar delitos genéricos, debes centrarte en los riesgos tecnológicos que afectan a ACME:

- Identifica 5 delitos informáticos específicos (basados en el Código Penal) en los que ACME podría incurrir como persona jurídica si sus sistemas fallan o son usados maliciosamente por empleados.
- Para cada delito, describe un escenario realista dentro de ACME (ej: "Un administrador de sistemas descontento...").

Respuestas 1

Basándonos en la información de la unidad y dada la actividad de ACME S.A, comentamos los supuestos 5 delitos informáticos que la compañía pudiera incurrir:

1. Delitos contra la intimidad, allanamiento informático y otros delitos informáticos.

ESCENARIO REALISTA:

- Un administrador de sistemas descontento accede sin autorización a las bases de datos de clientes para obtener información confidencial, utilizando algún usuario con privilegios.

2. Daños informáticos.

ESCENARIO REALISTA:

- Un empleado instala algún tipo de malware o borra algún backup críticos de la organización, provocando interrupciones del servicio de telecomunicaciones.

3. Estafas y fraudes.

ESCENARIO REALISTA:

- Un trabajador manipula sistemas de facturación para modificar o desviar la facturación de algunos clientes.

4. Delitos contra la propiedad intelectual e industrial, el mercado y los consumidores.

ESCENARIO REALISTA:

- Un empleado instala software sin licencia o descarga contenidos protegidos para uso interno de la empresa.

5. Blanqueo de capitales.

ESCENARIO REALISTA:

- Un ciberataque o uso indebido de sistemas permite ocultar transferencias sospechosas de clientes o manipular registros financieros para encubrir actividades ilícitas.

Apartado 2: Matriz de Riesgo y Controles Mitigantes

Con los 5 delitos identificados en el apartado anterior:

1. **Elabora una Matriz de Riesgo Penal:** Asigna valores de Probabilidad (1-5) e Impacto (1-5) justificando brevemente por qué en cada caso.
2. **Propón una Medida de Mitigación TÉCNICA** para cada uno.
 - No valen respuestas genéricas.
 - Debes proponer controles de ciberseguridad

Respuestas 2

En base a los datos del ejercicio anterior realizamos la siguiente Matriz:

MATRIZ DE RIESGO PENAL

		Probabilidad				
Impacto		1	2	3	4	5
	5				Acceso ilícito a sistemas informáticos	
	4			Daños informáticos	Estafas y fraudes	Revelación de secretos
	3					
	2		Delitos contra la propiedad intelectual			
	1					

La justificación sería la siguiente:

- Acceso ilícito a sistemas informáticos:
Es probable que empleados con privilegios intenten acceder a datos sensibles de clientes si no hay controles estrictos. El impacto sería crítico porque se compromete información confidencial.
- Revelación de secretos:
Posible que personal descontento filtre información confidencial. El impacto es crítico por exposición de datos de clientes y posible daño reputacional.
- Daños informáticos:
Posible que empleados instalen software malicioso o borren backups por descuido o malicia. El impacto sería crítico, interrumpiendo servicios esenciales.
- Estafas y fraudes:
Es posible que se manipulen sistemas de facturación si no hay controles eficaces en el software financiero. El impacto es grave, afectando a clientes y contratos.
- Delitos contra la propiedad intelectual e industrial:
Improbable que empleados usen software pirata, pero si ocurre, puede generar sanciones y demandas legales

Proponemos la siguiente **Medida de Mitigación TÉCNICA**:

- **Acceso ilícito a sistemas informáticos:**
Implementar un departamento para tener un servicio de IAM (Identity & Access Management) con control de roles, autenticación multifactor (MFA) y alertas de accesos no autorizados.
- **Revelación de secretos:**
DLP (Data Loss Prevention) para detección de fugas de información y cifrado de datos.
Monitoreo de logs y alertas automáticas ante exportación masiva de datos.
- **Daños informáticos:**
Backup redundados en diferente soporte y con diferente periodicidad y retención, registro de cambios en sistemas críticos, monitorización continua de actividades de usuarios privilegiados.
- **Estafas y fraudes:**
Auditorías recurrentes de los servicios contables y las transacciones que se puedan realizar, MFA en sistemas de pago y alertas de transacciones sospechosas.
- **Delitos contra la propiedad intelectual e industrial:**
Inventario de software corporativo (CMDB), bloqueo de descargas P2P y sitios de software no autorizado mediante firewall, auditorías periódicas de licencias.

Apartado 3: Adecuación a la Ley 2/2023 y NIS2

La Dirección quiere "cumplir con la ley gastando lo mínimo", pero tú debes asesorarles correctamente.

1. Canal de Denuncias: Redacta un pliego de 3 requisitos técnicos y funcionales que debe tener el software del Canal de Denuncias para cumplir rigurosamente con la Ley 2/2023 (anonimato, gestión de accesos, etc.). Explica por qué un correo electrónico normal (denuncias@acme.com) NO es válido.
2. Responsabilidad Directiva (NIS2): Escribe un breve párrafo (máximo 10 líneas) dirigido al CEO explicando por qué la ciberseguridad ya no es solo un problema del departamento de informática, sino una responsabilidad legal directa de la alta dirección bajo la directiva NIS2.

Respuestas 3

Pliego de requisitos técnicos para el canal de denuncias:

El software para el Canal de Denuncias de ACME S.A. debería cumplir estos tres puntos mínimos:

1. Anonimato del denunciante:

El sistema debe permitir enviar denuncias sin que se pueda identificar quien las envía. Esto se logra usando cifrado de extremo a extremo y anonimización. Sin esto, no se cumple la Ley 2/2023 y el denunciante podría quedar expuesto.

2. Control de accesos y trazabilidad:

Solo el personal autorizado indicado debe poder ver y gestionar las denuncias. El software debe tener roles de acceso, autenticación fuerte (con doble factor) y registros de auditoría que muestren trazabilidad.

3. Seguridad e integridad de la información:

Las denuncias deben almacenarse cifradas y de forma que no se puedan modificar. Además, el sistema debe permitir seguimiento de cada caso.

ANEXO Adicional de requisitos:

Un email tipo denuncias@acme.com

No garantiza anonimato, puede ser leído por personal no autorizado o hackers, y no deja evidencia de cómo se gestionó la denuncia. Por eso no cumple la ley ni protege a la empresa ni a los empleados ni a sus accionistas.

Responsabilidad Directiva – NIS2

Att CEO:

Debido a la aprobación de la Directiva Europea NIS2 (Directiva 2022/2555), nuestra compañía de Telecomunicaciones para a considerarse una entidad de servicios esenciales y por lo tanto el escenario se endurece de forma notable con respecto a nuestras obligaciones.

La ciberseguridad ya no es solo tema de IT: Los directivos de la compañía ahora son responsables directos de la ciberseguridad. Si no aprueban las medidas de seguridad necesarias y ocurre un ciberataque grave, puede haber sanciones económicas o incluso pueden ser inhabilitados temporalmente para ejercer cargos directivos.

Por eso es clave que la dirección supervise la seguridad, gestione riesgos, implemente protocolos de respuesta además de documentarlo.

Un saludo y muchas gracias por su colaboración.